

INTERNAL CONTROL POLICY

Version 1.0

Revision Date: August 24, 2026

Contact: security@prompthalo.com



DOCUMENT INFORMATION

Document Family	Governance, Ethics, and Security
Document Title	Internal Control Policy
Document ID	POL-IC-001
Current Version	1.0
Approved Date	August 24, 2026
Approved By	Information Security Steering Committee
Effective Date	August 24, 2026
Next Review Date	August 24, 2027
Classification	Internal
Document Owner	Chief Executive Officer — Accountable Party
Prepared By	Security Officer
Review Cycle	Annual, or upon material change
Supersedes	N/A
Audience	All personnel, including employees and contractors

APPROVERS AND OWNERS

Name	Role	Information Security Role	Signature	Date
Madhuri Chandoor	Approver	CEO and Founder		August 24, 2026
Praveen Sharma	Owner / Author	Fractional CISO/Security Officer		August 24, 2026

COMPLIANCE

This Policy is authorized by the Information Security Policy (POL-ISP-001) and supports the SOC 2 Trust Services Criteria for the Security category, principally CC1.1 through CC1.5, CC2.2, CC2.3, CC3.1, CC3.3, CC3.4, CC4.1, CC4.2, CC5.1, CC5.2, CC5.3, CC8.1 and CC9.2. It states how the Company's controls are owned, operated and evaluated as one system.

DOCUMENT VALIDITY

This document is valid only in its published electronic form in the PromptHalo Technologies policy repository. Printed or locally saved copies are uncontrolled and must be verified against the published version before use. This document is classified Internal and may not be distributed outside PromptHalo Technologies or its authorized clients without the written approval of the Security Officer.

TABLE OF CONTENTS

1 OVERVIEW AND PURPOSE	5
2 SCOPE	5
3 ROLES AND DEFINITIONS.....	5
4 TERMINOLOGY	5
5 THE CONTROL ENVIRONMENT	6
6 CONTROL OWNERSHIP AND ACCOUNTABILITY	7
7 EVALUATION OF INTERNAL CONTROLS.....	7
8 DEFICIENCIES AND CORRECTIVE ACTION	8
9 CHANGES AFFECTING INTERNAL CONTROL.....	8
10 COMMUNICATION WITH EXTERNAL PARTIES	9
11 RECORDS	9
12 ENFORCEMENT.....	10
13 EXCEPTIONS.....	10
14 REFERENCE.....	11
15 DOCUMENT POLICY HISTORY.....	ERROR! BOOKMARK NOT DEFINED.

1 Overview and Purpose

PromptHalo Technologies (“the Company”) maintains a system of internal control so that its assets are safeguarded against loss, its operations run efficiently, and its stated policies are actually followed rather than merely published. This Policy describes how that system is designed, who owns it, how it is evaluated, and what happens when part of it is found not to work.

This Policy does not create a second control programme alongside the Information Security Policy. It states how the controls authorized by that policy and its subordinate documents are owned, operated and evaluated as one system, so that a reader can tell what the Company relies on and how it knows the reliance is justified.

2 Scope

This Policy applies to all personnel, to all Company-owned or Company-managed information assets, and to the applications, infrastructure, systems and data through which the Company delivers its service. It covers controls of every kind — technical, administrative and physical — whether operated by the Company or by a vendor on its behalf.

This Policy is written for a company of the Company's current size and is to be read that way. Where a requirement here would take longer to perform than the risk it addresses would cost, the lighter form is used and the reason is recorded. Where a review required by this Policy finds that nothing has changed, recording that finding satisfies the requirement.

3 Roles and Definitions

1. “The Company” refers to PromptHalo Technologies.
2. The CEO or, in their absence, the Security Officer (the “Accountable Party”) owns this Policy and is accountable for the existence and effectiveness of the internal control system. [SOC 2: CC1.3]
3. The Information Security Steering Committee approves this Policy, reviews it at least annually, and receives the reporting required by Section 8. [SOC 2: CC1.2]
4. The Security Officer maintains the control matrix, coordinates the evaluations required by Section 7, and tracks deficiencies to closure in the plan of action maintained under the Information Security Policy. [SOC 2: CC4.2]
5. Each control has a named individual as its owner, not a role alone. Where a role is recorded, the individual holding it at the time is identified. [SOC 2: CC1.3, CC5.1]

4 Terminology

The following terms have the meanings given below wherever they appear in this Policy. Terms defined in the Information Security Policy carry the same meaning here and are not redefined.

1. **Control** — an activity, automated or manual, performed on a defined cadence that produces evidence it occurred.

2. **Control matrix** — the record of the Company's controls, identifying for each one the risk it treats, its owner, its cadence, whether it prevents or detects, and the evidence it produces.
3. **Control environment** — the structures, reporting lines, standards of behavior and management attitude within which controls operate.
4. **Deficiency** — a control that is absent, not operating as described, or not producing evidence.
5. **Detective control** — a control that identifies that an undesired event has occurred, so that it can be responded to.
6. **Evidence** — the record a control produces showing that it operated, sufficient for a reviewer to reach the same conclusion as the operator.
7. **Plan of action** — the single record of control deficiencies and corrective actions maintained under the Information Security Policy.
8. **Preventive control** — a control that stops an undesired event from occurring.
9. **Self-assessment** — an evaluation of whether a control operated as described over a period, performed by the Company rather than an external examiner.
10. **Significant change** — a change meeting the trigger criteria in the Risk Management Policy that requires risk reassessment.

5 The Control Environment

1. Senior management recognizes that the control environment provides the discipline and structure within which the Company achieves its objectives, and that controls operate only as well as the environment they sit in permits. [SOC 2: CC1.1]
2. The standards of behavior and ethical values expected of personnel are set out in the Code of Conduct, which personnel acknowledge on hire and annually thereafter. [SOC 2: CC1.1]
3. Security responsibilities are defined for all roles, communicated in writing, and acknowledged by personnel. The organization chart records reporting lines and includes contractors. [SOC 2: CC1.3, CC1.4]
4. Segregation of duties is applied where practicable. Where the Company's size prevents full segregation, the compensating control is recorded on the Annual Control Environment Assessment form and reviewed at each annual assessment. [SOC 2: CC1.3, CC3.3]
5. The Company acknowledges that its current size limits the independence available within the control environment. That limitation is carried as a discrete entry in the risk register with its compensating control, rather than treated as an absence of risk. [SOC 2: CC1.2, CC3.3]
6. Personnel report suspected control failures, policy violations and incidents to the Security Officer. Concerns regarding the conduct of the Security Officer may be raised through the ethics reporting route published in the Code of Conduct. [SOC 2: CC1.1, CC2.2]

6 Control Ownership and Accountability

1. The Company maintains a control matrix recording, for each control, the risk it treats, its named owner, its cadence, whether it is preventive or detective, and the evidence it produces. [SOC 2: CC5.1, CC5.2]
2. Controls are selected in response to risks identified under the Risk Management Policy. A control is not adopted because a framework lists it; it is adopted because it treats a risk the Company has recorded. [SOC 2: CC5.1, CC3.1]
3. Control selection considers whether an activity prevents or detects the risk it treats, and the matrix records which. Where a risk is treated only by detective controls, that position is deliberate and recorded. [SOC 2: CC5.1]
4. Each control owner is responsible for operating the control on its cadence and for retaining the evidence it produces. Lines of accountability are reviewed at least annually and corrected where performance measures are not being met. [SOC 2: CC1.3, CC4.1]
5. Where a control is operated by a vendor on the Company's behalf, the control matrix records that fact and identifies the Company-side control that confirms it is operating. Vendor controls are governed by the Vendor Management Policy. [SOC 2: CC9.2]
6. The annual control environment assessment considers whether any individual holds more control responsibilities than they can reasonably discharge, and records the conclusion. [SOC 2: CC1.3, CC1.5]

7 Evaluation of Internal Controls

1. Internal control processes and procedures are reviewed by senior management at least annually. The review confirms that controls are operating effectively and remain aligned to business objectives. [SOC 2: CC4.1]
2. Control objectives are identified by their relevance to the Company, the department, the business line or the product, so that the evaluation is scoped to what the control is for rather than to the document that describes it. [SOC 2: CC3.1, CC4.1]
3. The evaluation includes a review of the pertinent policies, procedures and documentation, and of the evidence each control produced during the period under review. [SOC 2: CC4.1]
4. Senior management may sample controls for review rather than testing every control every year. Where sampling is used, the basis of selection is recorded, and controls treating higher-rated risks are reviewed in preference to those treating lower-rated risks. [SOC 2: CC4.1]
5. Self-assessments are not performed solely by the person who operates the control. Where the Company's size prevents assignment to an independent assessor, the completed assessment is reviewed and signed by the CEO. [SOC 2: CC4.1]
6. A member of management, or a designee, documents the review and signs it off. Findings are shared with the parties who need to act on them. [SOC 2: CC4.1, CC2.2]

- 106 7. Outdated or non-operating procedures identified by the review are updated or removed, and
107 new controls are implemented where the review shows they are needed. [SOC 2: CC4.2, CC5.2]
- 108 8. The annual control environment assessment is recorded on the Annual Control Environment
109 Assessment form (FRM-CE-001). The evaluations required by this Section may be performed as a
110 single annual exercise, provided each required element is separately recorded. [SOC 2: CC1.2,
111 CC4.1]
- 112 9. Where a client agreement requires it, an independent examination such as a SOC 2 audit
113 supplements but does not replace the evaluation required by this Section. [SOC 2: CC4.1]

114 8 Deficiencies and Corrective Action

- 115 1. Identified control failures and deficiencies, and the corrective action plans proposed for them,
116 are addressed and communicated to management. [SOC 2: CC4.2]
- 117 2. Deficiencies are recorded in the plan of action maintained under the Information Security Policy,
118 with an assigned owner and a remediation date, and are tracked to closure by the Security
119 Officer. This Policy does not establish a separate deficiency register. [SOC 2: CC4.2, CC5.3]
- 120 3. Identified issues are assessed to determine their impact on internal control. Where the impact
121 warrants it, a corrective action plan is developed, documented and monitored until
122 implementation. [SOC 2: CC4.2]
- 123 4. A deficiency is closed only when the corrective action has been verified as effective and the
124 verification has been recorded, identifying who verified it and the date. Recording a corrective
125 action as performed does not close the deficiency. [SOC 2: CC4.2]
- 126 5. Failure to perform a scheduled control activity or evaluation by its due date is itself a deficiency,
127 and is recorded and escalated whether or not the activity is subsequently performed. [SOC 2:
128 CC4.2, CC5.3]
- 129 6. Deficiencies are assigned a severity and reported in writing to the Information Security Steering
130 Committee at least quarterly, in the report required by the Information Security Policy.
131 Deficiencies open beyond their agreed remediation date are escalated in that report. [SOC 2:
132 CC2.2, CC4.2]
- 133 7. A deficiency previously closed and since reopened is escalated as a concern with the design of
134 the control, rather than remediated again on the same terms. [SOC 2: CC4.2]

135 9 Changes Affecting Internal Control

136 Where a corrective action or other change is required, management assesses what the change does to
137 the system of internal control before it is made.

- 138 1. The assessment considers changes in the external environment, the current business model,
139 leadership, and business relationships including vendors, business partners and other third
140 parties. [SOC 2: CC3.4, CC9.2]

2. All changes to internal control activities are approved by management before implementation. [SOC 2: CC8.1]
3. Where the change affects the security of network or IT resources, it is approved and documented in accordance with the Change Management Policy. This Policy does not create a parallel change process. [SOC 2: CC8.1]
4. Where the change meets a reassessment trigger, the Risk Management Policy governs the reassessment, and closing the change includes updating the control matrix, the System Security Plan and the asset inventory as applicable. [SOC 2: CC3.4, CC2.1]
5. Changes to internal control activities are communicated to all affected personnel in a timely manner, and the communication is recorded. [SOC 2: CC2.2, CC8.1]
6. Where a control is retired, the record states which risk it was treating and how that risk is now treated. A control is not removed merely because it has become inconvenient to operate. [SOC 2: CC5.1, CC5.2]

10 Communication with External Parties

1. The Company communicates with external parties regarding the functioning of internal control where a change is material to a nondisclosure agreement or to contractual confidentiality and privacy provisions. [SOC 2: CC2.3]
2. An assessment is made of whether a change needs to be communicated to, and affirmed by, a customer, partner, vendor or other third party. The manner of communication is proportionate to the significance of the change. [SOC 2: CC2.3, CC9.2]
3. Communications carrying legal or regulatory implications are reviewed and approved by management before they are sent. [SOC 2: CC2.3]
4. The security, availability and confidentiality commitments the Company makes to customers are recorded and reviewed under the Information Security Policy. Where a change to internal control affects a recorded commitment, the commitment register is updated as part of closing the change. [SOC 2: CC2.3, CC1.5]
5. The Company publishes a monitored security contact address through which external parties may report control concerns, security issues and vulnerabilities without a customer relationship. [SOC 2: CC2.3]
6. Where the Company relies on a subservice organization, the carve-out method applies and the complementary user entity controls expected of customers are defined under the Information Security Policy. [SOC 2: CC9.2]

11 Records

1. The control matrix, including control owners, cadences and evidence types. [SOC 2: CC5.1]

2. Completed control self-assessments and the annual control environment assessment, with the reviewing signature. [SOC 2: CC4.1, CC1.2]
3. The plan of action, held under the Information Security Policy, recording deficiencies, owners, remediation dates and closure verification. [SOC 2: CC4.2]
4. Management sign-off of each internal control review, and the findings shared as a result. [SOC 2: CC4.1, CC2.2]
5. Approvals of changes to internal control activities, and the records of their communication. [SOC 2: CC8.1, CC2.2]
6. Communications to external parties regarding internal control, and any affirmations received. [SOC 2: CC2.3]
7. Records required by this Policy may be kept in the systems the Company already operates, provided they are retrievable and attributable. They are maintained as controlled records and are not reproduced in this Policy. [SOC 2: CC2.1]

12 Enforcement

1. Violations of this Policy may result in disciplinary action up to and including termination of employment or contract, and the Company may notify law enforcement of unlawful activity and cooperate in any investigation. [SOC 2: CC1.1, CC1.5]
2. The Security Officer documents the finding and recommends action. The CEO determines and documents the disciplinary outcome. This split applies wherever disciplinary action arises from a control or security matter. [SOC 2: CC1.1, CC1.5]
3. The Company does not consider conduct in violation of this Policy to be within an employee's or contractor's course and scope of work. [SOC 2: CC1.1]
4. Personnel asked to undertake an activity they believe violates this Policy must raise it with their manager, any other manager, or the ethics reporting route in the Code of Conduct, as soon as possible. [SOC 2: CC1.1, CC2.2]
5. The disciplinary process serves as a deterrent against violations of organizational policies and procedures, and is applied consistently. [SOC 2: CC1.1, CC1.5]

13 Exceptions

Exceptions to this Policy must be requested in writing to the Security Officer and approved by the Information Security Steering Committee. Approved exceptions are recorded with their rationale, their compensating control, the approver and an expiry date, and are reviewed at expiry.

Where a requirement of this Policy cannot be met proportionately at the Company's current size, the lighter alternative and the reason for it are recorded in the Governance Decisions Log, and the position is revisited at the annual review.

14 Reference

1. SOC 2 Trust Services Criteria, Security category [CC1.1 through CC5.3, CC8.1, CC9.2]
2. POL-ISP-001 Information Security Policy [SOC 2: CC4.2, CC5.3]
3. POL-RSK-001 Risk Management Policy [SOC 2: CC3.1, CC3.4]
4. POL-CM-001 Change Management Policy [SOC 2: CC8.1]
5. POL-VM-001 Vendor Management Policy [SOC 2: CC9.2]
6. POL-COC-001 Code of Conduct [SOC 2: CC1.1]
7. POL-HRS-001 Human Resources Security Policy [SOC 2: CC1.4]
8. FRM-CE-001 Annual Control Environment Assessment [SOC 2: CC1.2, CC4.1]

15 Document Policy History

Version	Date	Description
1.0	August 24, 2026	Initial policy release